Proposal: automated AI review of GitLab merge requests — pilot

For: Team Leader, Gobierno de Santa Fe · Date: 2026-10-26 · Author: Bruno Aguilar

1. Executive summary

We propose an 8-week pilot of **PR-Agent** (open source, MIT) as an automatic first-pass reviewer on two repositories at git.santafe.gov.ar. On every merge request it posts a summary, inline review comments on the affected lines, and one-click code suggestions, minutes before a human looks. It needs no change to Jenkins and never approves or merges.

In a local demo the tool found 9 of 9 seeded defects with Model A. Of the 4 defects that need real reasoning, it found 4. It produced 0 false positives across 4 merge requests, cost about USD 0.012 per merge request (code suggestions not metered), and took a median of 48 s from opening to complete feedback.

Limits of this evidence: synthetic code that we wrote ourselves, n = 9 defects, one run per model, unblinded scoring, and small diffs (≤150 lines). The cheaper Model B also found 9 of 9, so this set does not separate models. Real results will differ.

Code diffs are sent to an external model provider, so data protection must be resolved before use beyond the pilot (§5).

2. What was demonstrated

The setup was GitLab CE 19.5.1 and PR-Agent 0.48.0 in Docker on a laptop, reviewing a synthetic Java 21 repository: three merge requests with seeded defects, and one clean refactor to probe false positives. Only synthetic code was sent to the model provider; nothing from git.santafe.gov.ar.

Two models were used, both via OpenCode Go (a subscription gateway to open-weights coding models):

- **A** = GLM-5.3 (Z.ai)
- **B** = DeepSeek V4.1 Flash (open weights, cheaper per token)

Metric (definitions in `docs/results.md`)	Model A	Model B
Seeded defects found by `/review` (of 9)	9	9
Hard defects found (of 4: pagination ×2, null refund, stale cache)	4	4
False positives (4 MRs; clean MR in brackets)	0 (0)	0 (0)
Median time to review comment (s)	13.3	24.8
Mean cost per `/review` (USD)	0.0067	0.0024

Also shown:

- Repository conventions supplied to the model through an `AGENTS.md` file.

- Model switching with one comment. PR-Agent reaches models through LiteLLM (100+ providers), so changing vendor, or moving to a self-hosted model, is a one-line setting.
- Automatic re-review after a pushed fix (10 s): fixed bugs moved to “Resolved findings” and unfixed ones stayed open. Inline threads close only when their own line changes.

3. Tool choice and licences

Option	Licence / commercial model	Assessment
PR-Agent (github.com/The-PR-Agent/pr-agent)	MIT	~13.5k stars, 412 contributors. Community-maintained since Qodo moved its main product elsewhere (Qodo remains a sponsor). Releases about every 2 weeks (0.47.0 on 2026-10-02, 0.48.0 on 2026-10-16). Self-hosted webhook server for GitLab; any provider via LiteLLM. **Chosen.**
Kodus	AGPL-3.0 core + commercial enterprise edition	Viable; AGPL duties if modified and offered over a network; some features paid.
GitLab Duo Code Review	Proprietary GitLab add-on	Licensing tier varies by GitLab version (confirm with our account); data handled by GitLab’s model vendors.

Not evaluated: GitLab Duo Self-Hosted and Qodo’s commercial product.

Licence	What it means for us
MIT (PR-Agent)	Use, modify and run internally; keep the notice. Lowest risk; we can fork if upstream stops.
AGPL-3.0 + commercial EE (Kodus)	If modified and offered to users over a network, we must publish our changes; paid features sit outside the open core.

Model licences and provider terms are separate from the tool’s licence.

4. Production architecture

- **Deployment.** One PR-Agent container on a VM in the DMZ behind a TLS reverse proxy.
  - git.santafe.gov.ar sends webhooks (merge request and comment events) with a shared secret.
  - Egress is allow-listed to git.santafe.gov.ar and the model endpoint only.
  - The image is pinned by tag **and** `@sha256` digest. The image disables LiteLLM’s remote price-list download.
- **Credentials.** A **project access token** (Developer role, `api` scope, with expiry), or a dedicated bot user, rotated on a calendar and kept in the VM’s secret store.
- **Webhooks.** Per project. If the VM address is internal, a GitLab admin must allow-list it.

- **Logging.** PR-Agent keeps no database. Set `log_level=INFO`: the default DEBUG logs full prompts, including code. Review comments are stored in GitLab like any human comment.
- **Version gap.** The demo used GitLab CE 19.5.1; our version is unknown (PR-Agent needs ≥ 15.7). Verify in week 1.

5. Data protection

The current design sends **merge-request diffs and related file context** outside the government network:

- to the model vendor;
- in the demo route, additionally to **OpenCode Go**, an intermediary gateway (single-user subscription; not usable for a team pilot).

Options:

1. **Commercial API with zero-data-retention and no-training terms**, contracted directly with the model vendor, removing the intermediary. This is the fastest option, but data still leaves the country.
2. **Self-hosted open-weights model** (e.g. the GLM or DeepSeek families on vLLM) on a GPU server inside the network, so no code leaves. Demo results are indicative only (third-party hardware); quality on our hardware must be measured, and the GPU server quoted.

In every case:

- Exclude sensitive paths through PR-Agent's ignore list.
- Pilot only on repositories without real personal data.
- Keep `add_user_to_requests` off in production; it sends MR URLs to the provider.
- Keep DEBUG logging off.

We recommend a review under **Ley 25.326** and the government's ICT and information-security policies, approved by legal, the information-security office and the infrastructure owner. This document makes no legal determination.

6. Costs and operations

- **Model usage.** About USD 0.012 per merge request with Model A (description + review, at list prices). Model B costs 0.36 × Model A per review.
  - Real diffs are larger than the demo's, so treat this as a floor.
- **Infrastructure.** One small VM. No licence fees.
- **Maintainability.**
  - Behaviour is configuration only (environment variables and `.pr_agent.toml`); there is no custom code.
  - Model IDs that are not in PR-Agent's registry need `custom_model_max_tokens`; reasoning models also need an explicit reasoning-effort setting, otherwise calls time out.
  - The default fallback model must be overridden.
  - Input is capped at 32k tokens per call.

- **Upgrades.** The demo repository and answer key are our regression suite. Re-run them on every PR-Agent upgrade or model change before rollout. Upgrade monthly, or when a security fix lands.

7. Pilot plan and risks

- **Weeks 1–8:** 2 volunteer repositories. Baseline first: median time-to-first-review from the GitLab API. Every week, developers tag bot comments as useful, noise or wrong.
- **Success criteria (thresholds set by the Team Leader):**
  - Useful comments ≥ ___ %.
  - Wrong comments ≤ ___ %.
  - Spend ≤ cap.
  - Zero data-protection incidents.
- **Stop rule:** any secret or personal-data incident, or a spend breach.

Risk	Mitigation
Code or data leaves the network	Option 1 or 2 in §5; ignore paths; legal and security review before extending
Wrong or noisy comments erode trust	Comments are advisory; findings capped; weekly precision tagging; tune instructions
Upstream is community-maintained, not vendor-supported	Pin by digest; MIT allows forking; regression suite on each upgrade
Token or secret compromise	Least-privilege project token with expiry; webhook secret; secrets outside repositories

PR-Agent never approves or merges. Human approval is enforced by GitLab approval rules (tier-dependent) or by the “Allowed to merge” setting on protected branches.

8. Decision requested

1. Approve an 8-week pilot on 2 repositories named by the team.
2. Provide one VM, plus network rules: inbound webhook from git.santafe.gov.ar, outbound HTTPS to the chosen provider.
3. Approve a model spend cap of USD 50/month.
4. Assign an owner and start the legal and information-security review.
5. Choose the pilot model route: a commercial zero-retention API (fastest), or self-hosted (requires a GPU budget).